Автономная некоммерческая организация высшего образования
«Санкт-Петербургский институт экономики и управления»



Кафедра **09.02.07 Информационные системы и программирование**

ПРАКТИЧЕСКАЯ РАБОТА № 7

Дисциплина(модуль)/предмет **МДК.03.02**

Тема: **Анализ угроз и уязвимостей**

ВАРИАНТ № **3**

Студент (ка)/учащийся: **Бойцов Даниил Антонович** / _____ /
Ф. И. О. подпись

Группа / Класс **И13-24-11**

Руководитель: **Чудинова А.А.** /_____ /
Должность, степень, Фамилия и инициалы подпись

Дата представления работы «04» ноября 2026 г.

Работа аттестована с оценкой _____
прописью

Санкт-Петербург
2026 г.

Содержание

1 Потоки данных и границы доверия 3
2 Матрица угроз STRIDE и OWASP 4
3 Эшелоны защиты и остаточные риски 5
Подтверждающие материалы 6
Заключение 7
Список использованных источников 8

1 Потоки данных и границы доверия

Цель работы: построить DFD модуля Climate Control и выявить угрозы STRIDE. Защищаемые активы: целостность показаний, ключ датчика, привязка к помещению, доступность API и доказательства принятых решений. Входящий датчик считается недоверенным до проверки сообщения.

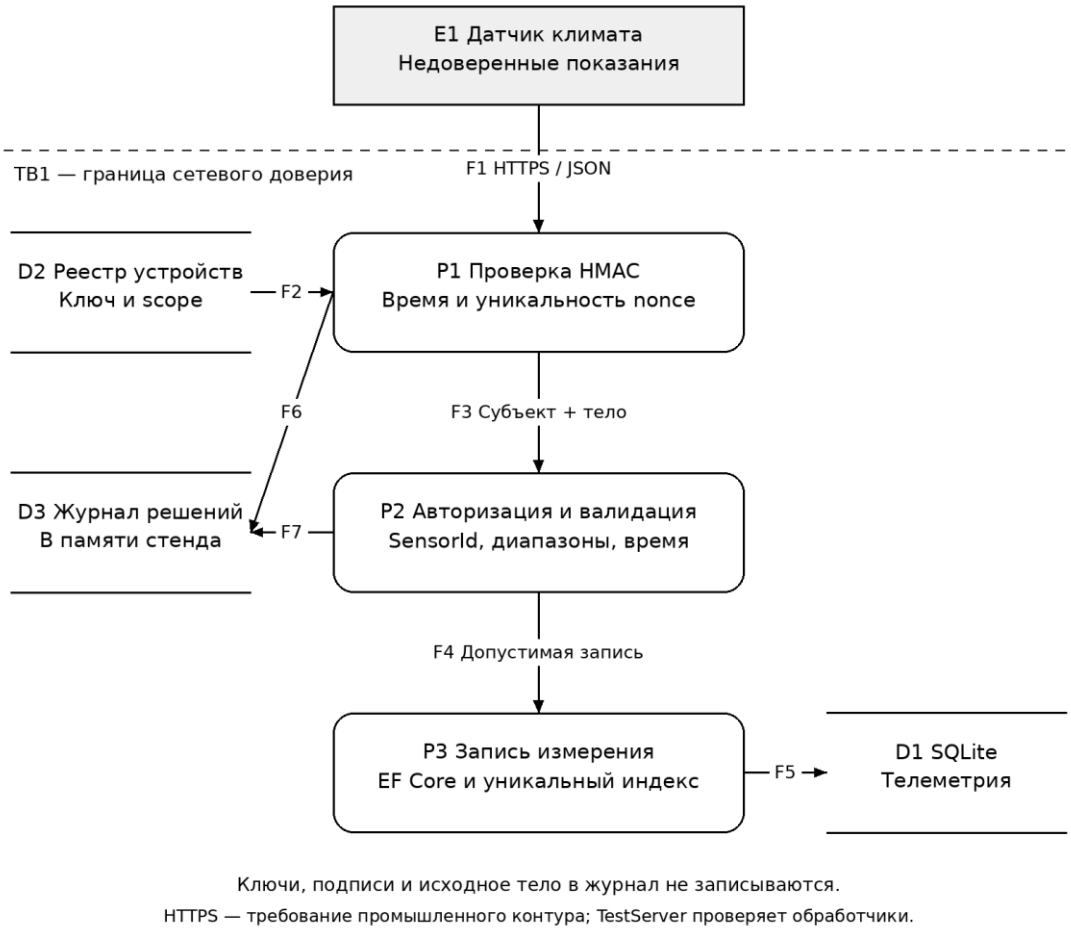


Рисунок 1 — DFD приёма телеметрии и граница доверия

F1 — JSON и HMAC-заголовки; F2 — ключ и права из реестра; F3 — подтверждённый субъект и тело; F4 — проверенная запись; F5 — параметризованная SQL-команда; F6/F7 — решения аутентификации и проверки. D3 обозначает ограниченный журнал в памяти стенда, а не защищённое постоянное хранилище.

2 Матрица угроз STRIDE и OWASP

STRIDE используется для систематического рассмотрения шести категорий угроз [1]. Сопоставление выполнено с OWASP Top 10 редакции 2025 года [2]; это аналитическая связь, а не тождество двух классификаций.

Категория	Сценарий и поток	OWASP 2025	Мера и проверка
S Подмена личности	F1: посторонний выдаёт себя за зарегистрированный датчик.	A07 Authentication Failures	HMAC и серверный реестр; I02, S08.
T Изменение данных	F1: температура меняется после подписания; либо повторяется старое тело.	A08 Software or Data Integrity Failures	Подпись контекста и тела, время, nonce; S01, S04, S05.
R Отказ от авторства	F6/F7: нет записи о том, почему показание принято.	A09 Security Logging and Alerting Failures	Журнал решения без секретов; S09. Постоянная защита аудита требует развития.
I Разглашение	F1/F2: перехват телеметрии или утечка ключа.	A04 Cryptographic Failures	TLS, внешняя конфигурация ключей, минимизация логов. Сетевой TLS-тест не проведён.
D Отказ в обслуживании	F1: поток больших тел или частые подписи нагружают API.	A06 Insecure Design	Лимит тела 4096 и квота датчика; S06/S07. Нужен также внешний pre-auth лимит.
E Повышение привилегий	F3: датчик записывает данные от чужого имени или без write scope.	A01 Broken Access Control	Authorize policy и сверка SensorId; S02/S03.

Свойство HMAC не следует называть неотказуемостью: обе стороны знают общий ключ и способны вычислить подпись. Для юридически значимого авторства нужны иные механизмы и правила хранения. Учебный аудит обеспечивает наблюдаемость решений, но не заменяет такую систему.

3 Эшелоны защиты и остаточные риски

TB1 отделяет сетевой источник от доверенного серверного конвейера. TLS требуется на промышленной границе; TestServer проверяет обработчики без моделирования реального сетевого шифрования. Ключ не поступает вместе с сообщением и не копируется в журнал.

Эшелон	**Ответственность**	**Остаточный риск**
Сеть	TLS и сегментация устройств; ограничение доступа к API.	В стенде нет промышленного сетевого контура.
Идентификация	Ключ на устройство, keyId, HMAC контекста и тела.	Скомпрометированный датчик способен подписать ложное, но правдоподобное показание.
Свежесть	Окно времени и атомарное занятие nonce.	Кэш памяти очищается при перезапуске и не общий для нескольких узлов.
Полномочия и данные	Scope, SensorId, серверное помещение, диапазоны.	Физическая калибровка и выявление аномалий внутри диапазона не проверены.
Хранилище	EF Core и уникальный индекс.	Нужны резервирование, правила доступа к файлу и испытание отказа диска.
Контроль	Аудит решения и регрессионные тесты.	Нужна защищённая доставка журнала вне процесса.

Приоритет исправлений: подмена и чужая запись блокируются до сохранения; затем ограничиваются повторы и объём запроса. Для эксплуатации добавляются общий replay-store с атомарной операцией, ротация ключей, внешний rate limit до HMAC и защищённое хранилище аудита. Независимые предельные режимы оборудования не должны зависеть от одной телеметрической службы.

Подтверждающие материалы

Рисунок 2 дополняет материалы работы. На снимке показаны требования, по которым проверяются меры из матрицы угроз: полномочия устройства, ограничения нагрузки и состав записей журнала.

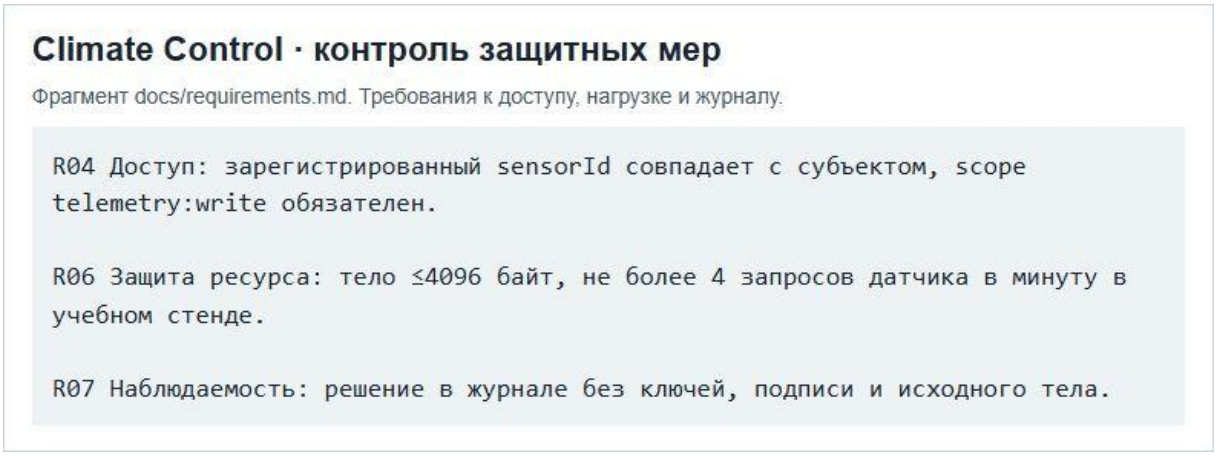


Рисунок 2 — Требования к контролю доступа, нагрузки и аудита

Материалы работы на GitHub: открыть раздел работы

Заключение

Построена DFD и описаны минимум по одной угрозе всех шести категорий STRIDE. Меры привязаны к потокам, категориям OWASP и проверкам. Отдельно указаны риски, которые программный стенд не устраняет.

Материалы относятся к модулю Climate Control варианта 3. Проверенный программный стенд не подключён к физическому отоплению или вентиляции кампуса. Промышленная приёмка оборудования в рамках работы не проводилась.

Список использованных источников

1. Microsoft Learn. Threats and STRIDE. URL: https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats.

2. OWASP. Top 10 2025. URL: https://top10.owasp.org/2025/.

3. Microsoft. HMACSHA256 API documentation. URL: https://learn.microsoft.com/en-us/dotnet/api/system.security.cryptography.hmacsha256.